YIFEI SUN

Principal Software Engineer · Infrastructure Security & Secure Distributed Systems · 13 Years

(617) 922-4823
sun1fei@gmail.com
linkedin.com/in/yifei-sun-a789861b

SUMMARY

Principal-level engineer with 13 years building secure distributed infrastructure, authentication platforms, and cloud-native systems at scale. Architected production IAM systems (Keycloak SSO, OAuth 2.0, SAML federation, custom token validation at gateway layer), deployed service mesh with mTLS for zero-trust service communication, and built secure API gateways with rate limiting and abuse prevention. Led multi-quarter platform redesign of high-traffic infrastructure serving millions of daily requests (p99 250ms→50ms, 99.9% availability), driving architecture and security standards across 10+ teams via RFCs and design docs. Currently building AI-powered tooling (MCP server, LLM-based validation) to automate detection and mitigation of security-relevant changes across distributed systems. Combines deep infrastructure security engineering with cross-organizational technical leadership in high-velocity, high-stakes environments.

LEADERSHIP HIGHLIGHTS

- Built production IAM platform: Keycloak SSO, OAuth 2.0/SAML federation, custom RBAC enforcement at API gateway, zero-trust service mesh (mTLS)
- Building AI-powered security tooling: LLM-based impact analysis and automated validation to detect breaking changes across service boundaries in CI
- Led planet-scale API redesign (8K rpm, millions daily): defined auth boundaries per service, circuit breakers, fault isolation, safe rollout strategy
- Drove cross-org security and architecture standards via RFCs, design docs, and ADRs — document-driven collaboration across distributed teams

Security & Infrastructure: OAuth 2.0, SAML, OIDC, Keycloak, JWT/token validation, RBAC/ABAC, mTLS, Service Mesh (Linkerd), Kong, Nginx · **Cloud & Platform:** AWS (ECS, EKS, IAM, KMS, SQS, SNS, S3, RDS), Terraform, Kubernetes, Docker · **Languages:** Java (13 yr), Python, Node.js/TypeScript, Golang (familiar) · **Data & Observability:** Kafka, Redis, PostgreSQL, Cassandra, Datadog, Grafana, Distributed Tracing · **AI/LLM:** OpenAI SDK, MCP Protocol, LLM-based automation & detection tooling

EXPERIENCE

CarGurus — Principal Software Engineer / Technical Lead

Oct 2019 – Present

AI-Powered Security Validation & Automated Risk Detection (Current Initiative)

- Designing and building an AI-powered cross-domain validation system that uses LLM-based impact analysis + deterministic spec validation to automatically detect security-relevant and breaking changes across service boundaries at PR time — shifting security review left into CI.
- Built MCP server (OpenAI Apps SDK) as sole backend engineer — defined API contracts, tool schemas, request/response interfaces, and access control boundaries for external AI consumer integration under strict security constraints.
- Architecture: rule-based pre-filter (fast, zero-cost) cascading to LLM semantic analysis only when cross-boundary impact detected; consumer registry tracks which services read which fields to flag breaking contract changes automatically.

Secure Platform Redesign — High-Traffic API Infrastructure

- Led 3 principal/senior engineers and aligned 10+ teams across 3 departments to redesign the core API platform (~8,000 rpm, millions of daily impressions), defining per-service authentication, authorization boundaries, circuit breaking, fault isolation, and idempotent retry across all service interactions.
- Architected orchestration layer consolidating 12 downstream integrations into 5 services with well-defined security contracts, eliminating shared-credential anti-patterns and enforcing least-privilege access at each service boundary.
- Built automated correctness verification infrastructure comparing new vs. legacy responses at 50% production traffic — enabling safe, data-driven rollout decisions with zero integrity regressions.

  p99: 250 ms → 50 ms (5×) **Availability: 98% → 99.9%** **Deploy: 1 hr → 3 min** (20×)

Cross-Org Architecture Standards & Security Engineering Culture

- Established reusable patterns for API security, auth enforcement, caching, and distributed orchestration adopted across multiple teams; authored design docs, RFCs, and architecture decision records.
- Led threat modeling and design reviews for major platform changes; mentored senior engineers on secure system design, cross-team strategy, and path to Principal-level scope.

Event-Driven Platform & Secure GraphQL Federation

- Led backend platform design using event-driven architecture (Kafka, SQS/SNS) with Terraform-managed AWS infrastructure and IAM-based access controls per service boundary.
- Designed Netflix DGS subgraph for federated GraphQL gateway with per-consumer authorization — unified, access-controlled API layer serving frontend, backend, and AI consumers.

Applause — Senior Software Engineer / Technical Lead

Oct 2017 – Oct 2019

IAM Platform — Identity Federation, Token Auth & Secure Gateway

- Architected production IAM platform: migrated legacy auth to Keycloak-based SSO with OAuth 2.0 and SAML identity federation, unifying authentication across internal systems, enterprise partner platform, and external community with fine-grained RBAC.
- Built custom token validation and RBAC enforcement plugins for Kong API gateway (Python) — per-request JWT validation against Keycloak, token refresh handling, session management, and permission checks at gateway layer before requests reach backend services.
- Deployed service mesh (Linkerd on Kubernetes) with mTLS for zero-trust service-to-service communication. Coordinated migration of multiple Java and Node.js services behind new auth gateway with minimal downtime, aligning 4 teams on consistent identity posture.

Event Sourcing & Secure Microservices Architecture

- Drove design of microservice architecture with event sourcing and CQRS; defined security isolation patterns, per-service data boundaries, and access control models adopted across new service domains.

Toast Inc. — Senior Software Engineer (Early Engineer)

Sep 2014 – Oct 2017

Core Platform Services & API Gateway Security

- Among the earliest engineers during hypergrowth; built core platform services (Order Service, Labor Service, REST APIs) with authentication, authorization, and input validation at every service boundary — systems that grew to process billions in GMV.
- Built custom API gateway (Nginx + Lua) implementing rate limiting, request authentication, traffic routing, and abuse prevention — the first security enforcement layer for all external API traffic before dedicated security teams existed.
- Set up initial AWS environment with Ansible — provisioned infrastructure, deployment pipelines, IAM policies, security groups, and monitoring. Established the foundational cloud security posture during rapid scaling.

Secure Third-Party Integrations & Partner Platform

- Led authenticated bidirectional API integrations with partners (workforce management) — schema validation, access control, credential rotation, and audit logging for all external data flows.

The MathWorks Inc. — Software Engineer II

Jul 2013 – Aug 2014

Developed internal engineering tools (Java) for MATLAB/Simulink workflows. Improved build/test automation and developer productivity tooling.

EDUCATION

M.S. in Electrical and Computer Engineering — Northeastern University, Boston 2010 – 2013

B.S. in Information Science — Beijing University of Aeronautics and Astronautics 2006 – 2010